

INCIDENT RESPONSE REPORT

SOC328 — Akira Ransomware Infection via Spearphishing Attachment

LetsDefend SOC Simulation | Prepared for Portfolio Use

Ediz YURDAGÜL | edizyurdagul@hotmail.com

Alert Rule	SOC328 - Akira Ransomware Infection
Threat Actor	Akira Ransomware Group
Affected Host	EC2AMAZ-ILGVOIN\LetsDefend (172.16.17.130)
Severity	Critical (P1)
Verdict	True Positive
Analyst Status	Contained

1. Executive Summary

An employee received a phishing email disguised as a payment confirmation invoice. Inside was a password-free ZIP archive containing a malicious executable. Once the user extracted and ran the file, it launched the Akira ransomware — a well-known criminal group that both encrypts files and steals data, then threatens to leak it if a ransom isn't paid (a tactic called "double extortion").

Once running, the malware tried to weaken Windows Defender to avoid being caught, encrypted files on the machine, and dropped a ransom note directing the victim to a dark-web chat portal. The infected host was quickly isolated from the network to stop the ransomware from spreading to other systems, and the incident was confirmed as a true, high-severity compromise.

This report explains what happened step by step in plain language, backed by screenshots and technical evidence, along with the indicators of compromise and recommendations to prevent a repeat.

2. Incident Details

Alert Rule	SOC328 - Akira Ransomware Infection
Threat Actor	Akira Ransomware Group
Affected Host	EC2AMAZ-ILGVOIN\LetsDefend
Affected Host IP	172.16.17.130
Severity	Critical (P1)
Verdict	True Positive
Malicious File	Payment Confirmation Invoice #12345.exe
SHA256 Hash	2c7aeac07ce7f03b74952e0e243bd52f2bfa60fadc92dd71a6a1fee2d14cdd77

VirusTotal Detection	59 / 70 vendors — ransomware.akira
MITRE ATT&CK	T1566.001, T1204.002, T1562.001, T1548.002, T1490, T1486

3. How Akira Ransomware Works (In Plain Terms)

Akira is a well-organized ransomware family that targets both Windows and Linux/VMware environments. Here's what makes it dangerous, explained simply:

- Strong, fast encryption: Akira scrambles files quickly using a lightweight cipher (ChaCha20 or AES-256), then locks the encryption key itself with a much stronger key (RSA-4096) that only the attacker holds. Without the attacker's private key, recovering the files is not mathematically feasible.
- Destroys your backups first: Before encrypting anything, Akira deletes Windows' built-in backup snapshots (Shadow Copies) using commands like `vssadmin delete shadows`, so victims can't simply restore their files from a local backup.
- Shuts down what's in its way: It stops database and security software processes so files aren't "locked" by other programs during encryption, and so antivirus/EDR tools are less likely to catch it in the act.
- Double extortion: Before encrypting anything, Akira operators quietly copy sensitive files out to their own servers. Even if a victim restores from backup and refuses to pay, the attackers threaten to leak or sell the stolen data on the dark web.

4. Step-by-Step Attack Timeline

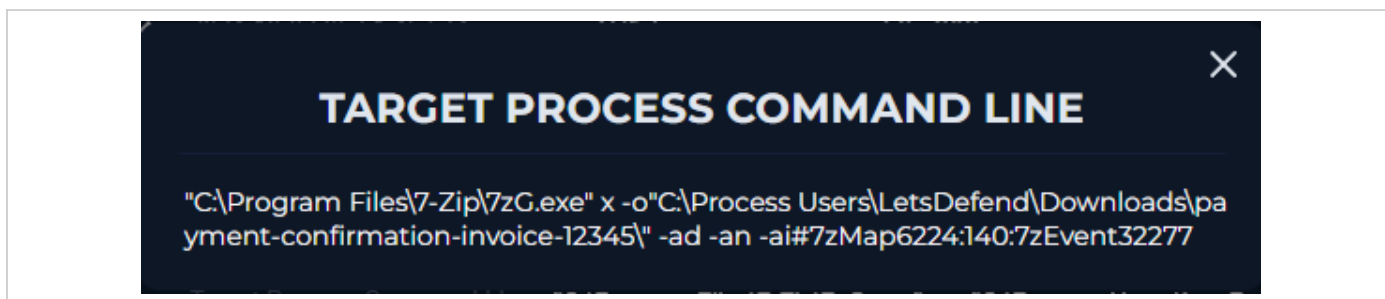
Step 1 — Initial Access, 05:25 UTC (T1566.001: Spearphishing Attachment)

The attacker sent a phishing email from `sale@therasted.com` to the victim (`vergil@letsdefend.io`), disguised as a payment confirmation invoice. The email carried a ZIP attachment containing the malicious executable.

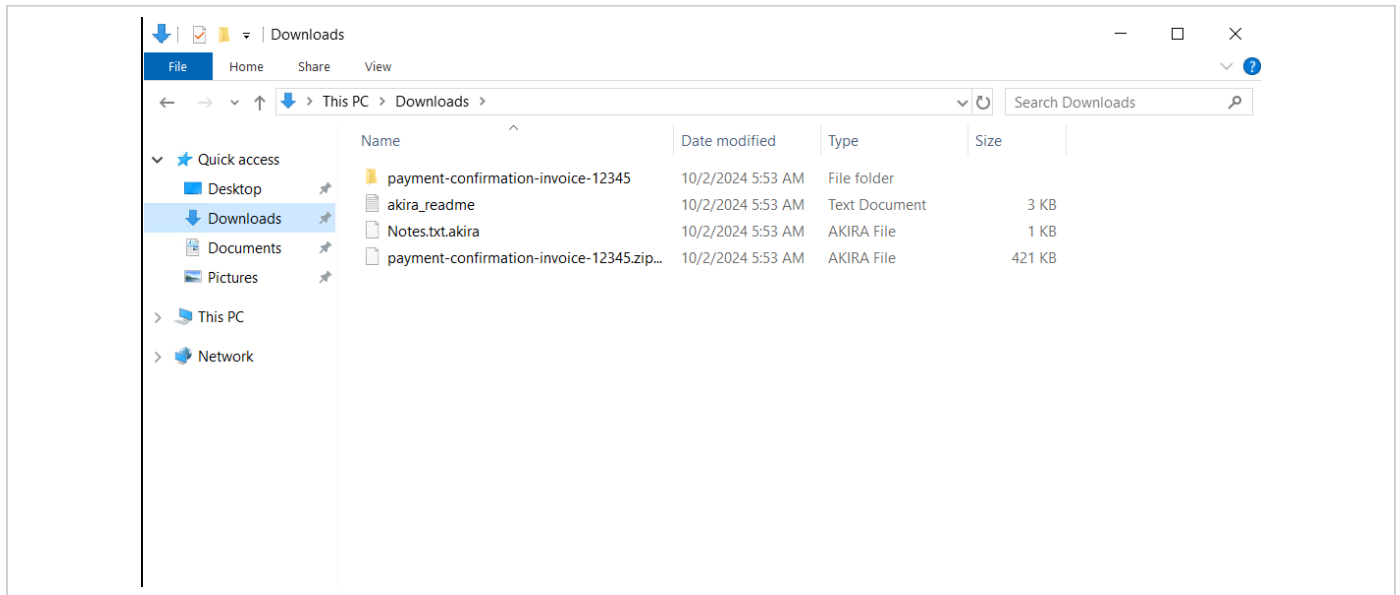
Step 2 — Execution (T1204.002: User Execution)

The victim extracted the archive using the built-in 7-Zip GUI (`7zG.exe`) into their Downloads folder and ran the file inside — `Payment Confirmation Invoice #12345.exe` — giving the ransomware a foothold on the machine.

```
"C:\Program Files\7-Zip\7zG.exe" x -o"C:\Users\LetsDefend\Downloads\payment-confirmation-invoice-12345" -ad -an -ai#7zMap6224:140:7zEvent32277
```



Target process command line — 7zG.exe extracting the malicious archive



Downloads folder — extracted Akira files, including the ransom note and encrypted marker files

Step 3 — Defense Evasion, 05:30–05:40 UTC (T1562.001 / T1548.002)

After execution, the malware attempted to weaken Windows Defender through registry changes launched via `cmd.exe / reg add`, and attempted to bypass User Account Control (UAC) to gain higher privileges — both aimed at operating without being blocked or noticed.

Step 4 — Inhibiting Recovery (T1490: Inhibit System Recovery)

Before encrypting files, Akira is designed to wipe out Windows' built-in recovery points (Shadow Copies) so the victim cannot simply roll back the damage — this is standard Akira behavior consistent with the infection observed here.

Step 5 — Impact, 05:52:10 UTC (T1486: Data Encrypted for Impact)

File encryption completed, and a ransom note (`akira_readme`) was dropped and opened automatically in Notepad. The note pressures the victim to pay quickly, threatens to leak stolen data, and provides Tor-based instructions to contact the attackers using a unique victim ID.

Whatever who you are and what your title is if you're reading this it means the internal infr:

Well, for now let's keep all the tears and resentment to ourselves and try to build a construc

1. Dealing with us you will save A LOT due to we are not interested in ruining your financial
2. Paying us you save your TIME, MONEY, EFFORTS and be back on track within 24 hours approxi
3. The security report or the exclusive first-hand information that you will receive upon re
4. As for your data, if we fail to agree, we will try to sell personal information/trade secre
5. We're more than negotiable and will definitely find the way to settle this quickly and re

If you're indeed interested in our assistance and the services we provide you can reach out t

1. Install TOR Browser to get access to our chat room - <https://www.torproject.org/download/>.
2. Paste this link - <https://akiralkxzq2dsrzsrvbr2xgbbu2wgsmxryd4csgfameg52n7efvr2id.onion>.
3. Use this code - 6729-HK-NIZN-WOPQ - to log into our chat.

Keep in mind that the faster you will get in touch, the less damage we cause.

Akira ransom note (akira_readme) — payment demand and dark-web contact instructions

Step 6 — Detection & Response

The infection was confirmed as a true positive. The affected host was immediately isolated from the network to prevent the ransomware from spreading to other machines (lateral movement), and the incident was escalated for full investigation.

5. Indicators of Compromise (IOCs)

Type	Value	Context
Sender Email	sale@therasted.com	Phishing sender
Sender IP	162.255.119.213	Phishing mail server
Malicious Archive	payment-confirmation-invoice-12345.zip	Email attachment
Malicious Executable	Payment Confirmation Invoice #12345.exe	Akira ransomware binary
SHA256 Hash	2c7aeac07ce7f03b74952e0e243bd52f2bfa60fadc92dd71a6a1fee2d14cdd77	Akira binary hash
VT Detection	59/70 — ransomware.akira	VirusTotal verdict
Extracted Path	C:\Users\LetsDefend\Downloads\payment-confirmation-invoice-12345\	Working directory

Ransom Note	akira_readme	Ransom note dropped after encryption
Execution Log	Log-02-10-2024-05-52-10.txt	Auto-opened alongside the ransom note
Affected Host IP	172.16.17.130	Infected internal machine
Negotiation Portal	akiralkzxzq2dsrzsrivr2xgbbu2wgsxmryd4csgfameg52n7efvr2id.onion	Akira Tor chat
Leak Site	akiral2iz6a7qgd3ayp3l6yub7xx2uep76idk3u2kol1pj5z3z636bad.onion	Akira dark-web leak blog
Victim ID	6729-HK-NIZN-WOPQ	Ransom tracking code

6. Evidence Notes & Scope

For transparency, here is what this report's evidence does and doesn't independently confirm:

- Defense evasion (Step 3) and shadow-copy deletion (Step 4) are documented based on Akira's well-known, consistent behavior pattern and the write-up's technical description; a direct command-line screenshot of the vssadmin/reg add execution was not captured for this report.
- Execution and impact (Steps 2 and 5) are backed by first-hand screenshots: the 7-Zip extraction command line, the resulting file listing, and the ransom note itself.
- No confirmation either way is made here about whether data was actually exfiltrated before encryption — this is inferred from Akira's known double-extortion pattern and the ransom note's threat, not independently verified via network traffic logs in this report.

7. Actions Taken & Prevention Tips

Actions Taken

- Confirmed the alert as a True Positive, Critical severity ransomware infection.
- Isolated the affected host (172.16.17.130) from the network to block lateral movement.
- Permanently blocked the sender address (sale@therasted.com) and IP (162.255.119.213) at the email security gateway.
- Collected file hashes, IOCs, and the ransom note for threat intelligence sharing and tracking.
- Escalated the incident for full forensic investigation and data-exfiltration assessment.

Prevention Recommendations

- Tighten email attachment filtering, especially for password-protected or unusual archive types often used to bypass scanning.
- Run regular, realistic phishing-awareness simulations focused on invoice/payment-themed lures.

- Adopt a 3-2-1-1-0 backup strategy: multiple copies, different media, one offsite, one offline/immutable (air-gapped, WORM storage), zero errors on recovery testing.
- Separate backup infrastructure from the main Active Directory domain so ransomware with domain access cannot also destroy backups.
- Enable tamper protection on endpoint security tools so ransomware cannot disable or weaken them mid-attack.
- Monitor for and alert on shadow-copy deletion commands (vssadmin, bcdedit, wmic) — a strong early warning sign of ransomware.

— *End of Report* —